

Script-Controlled ACL – Restrict Record Access Based on Field Value

Phase 1: Brainstorming & Ideation

1.1 Problem Statement

An institution stores student records (roll number, student, faculty, branch, contact details) in a single ServiceNow table. Without record-level security, every user with table access can see the data of every branch. Departments such as EEE should be able to see only their own branch records, and operations such as creating, editing and deleting must be separately controlled.

1.2 Objectives

- Restrict who can read records based on the value of the Branch field (only EEE records for EEE users).
- Use a script-controlled ACL so that the decision logic is programmable, not just role-based.
- Provide separate roles for READ (bb1), CREATE (bb2), WRITE (bb3) and DELETE (bb4).
- Ensure administrators retain full access to all records.

1.3 Empathy Map / Stakeholders

Stakeholder	Needs	Pain point today
EEE Department user	View (and, if permitted, manage) only EEE student records	Sees ECE and CSE data as well
Administrator	Full visibility and control of all records	No way to enforce fine-grained rules
Institution / Data owner	Protect student personal data (email, phone)	Risk of unauthorized viewing or modification

1.4 Ideas Considered

Idea	Assessment
Separate table per branch	Duplicates structure and maintenance; rejected.
Role-only ACL (no data condition)	Cannot restrict by Branch value; rejected.
Business Rule / Query Business Rule filtering	Works, but ACLs are the standard platform security layer; not chosen.
Script-controlled ACL with data condition (selected)	Combines role check, field condition and script; enforced on lists, forms and portal.

1.5 Proposed Solution & Scope

Create a custom table with a Branch choice field, create four custom roles, and define four record-level ACLs (read, create, write, delete). The read ACL is advanced: it requires role bb1,

applies a data condition (Branch is EEE) and runs a script that always allows admins.

In scope: one table, one test user, four roles, four ACLs, verification through impersonation.

Out of scope: field-level ACLs, integrations, production data migration.